CYBERSPLOIT 1 — CTF WALKTHROUGH

Reconnaissance → Enumeration → Credential Discovery → SSH → Kernel Privilege Escalation → Root

Lab-focused penetration testing / privilege escalation case study

1. Executive Summary

This walkthrough documents the complete attack path followed against the authorized Cybersploit 1 CTF virtual machine. The objective was to identify exposed services, discover credentials, obtain an SSH foothold, identify the vulnerable Linux kernel, retrieve the corresponding public exploit, compile it on the target, and escalate from the low-privileged user 'itsskv' to root.

The compromise chain was: network discovery → Nmap service enumeration → web/source-code analysis → username discovery → robots.txt credential discovery → Base64 decoding → SSH access → kernel/version enumeration → Exploit-DB research → OverlayFS privilege escalation → root.

2. Scope and Lab Details

Target	Cybersploit 1 CTF virtual machine
Target IP	192.168.29.32
Initial user	itsskv
Initial access	SSH
Privilege escalation	Linux kernel / OverlayFS vulnerability (Exploit-DB 37292)
Final privilege	root

3. Phase 1 — Start the Vulnerable Machine

The Cybersploit 1 vulnerable VM was started first. The Kali Linux system was used as the attacking workstation. Both systems were placed on the same lab network so the target could be discovered and accessed.

4. Phase 2 — Network Discovery

The first objective was to determine the target's IP address. Network discovery was performed from Kali using the local subnet. The discovered host was 192.168.29.32.

Example discovery workflow:

```
netdiscover
netdiscover -r 192.168.29.0/24
```

The important result from the discovery phase was the identification of the Cybersploit VM at 192.168.29.32.

5. Phase 3 — Nmap Enumeration

After identifying the target IP, Nmap was used to enumerate open ports and identify the services running on the host. Service/version detection is particularly useful because it provides clues about the software stack and possible attack paths.

```
nmap -sC -sV 192.168.29.32
nmap -p- -sC -sV 192.168.29.32
```

The enumeration revealed an HTTP service. This changed the attack path from simple network enumeration to web application/content discovery.

6. Phase 4 — Web Service and Source-Code Analysis

The web service was inspected in a browser. During the investigation, the source code of the web page was reviewed. Source-code analysis exposed a username that was useful for the next stage of the attack.

Key lesson: always inspect HTML source, comments, linked resources, robots.txt, JavaScript, and other publicly exposed web content during a CTF assessment.

7. Phase 5 — Username Discovery and SSH Testing

The username discovered during the web investigation was 'itsskv'. Since SSH was exposed, the next logical step was to test whether this account could authenticate over SSH.

```
ssh itsskv@192.168.29.32
```

Initially, authentication failed because the password had not yet been identified. The SSH banner warning about post-quantum key exchange was not the cause of the authentication failure; it was simply a security notice from the OpenSSH version in use.

8. Phase 6 — robots.txt and Credential Discovery

Web content discovery led to robots.txt. The file contained an unusual string. Rather than assuming it was random text, its encoding was investigated. The string was recognized as Base64.

Base64 decoding on Linux:

```
echo "BASE64_STRING" | base64 -d
```

Decoding the discovered value revealed the password used for the 'itsskv' account. This demonstrated an important CTF technique: encoded data is not necessarily encrypted data.

9. Phase 7 — SSH Foothold

```
ssh itsskv@192.168.29.32
```

The recovered password was supplied at the SSH prompt. Authentication succeeded and an interactive shell was obtained as the low-privileged user 'itsskv'.

10. Phase 8 — Local Enumeration

Once inside the target, local enumeration was performed. The first important command was uname -a, which identifies the kernel and system architecture.

```
uname -a
```

The output identified an old Ubuntu/Linux kernel, including the 3.13.0-32-generic kernel. The old kernel version was a strong indicator that local privilege-escalation vulnerabilities might be relevant.

11. Phase 9 — Vulnerability Research

The kernel version was researched against public vulnerability databases and Exploit-DB. The investigation identified Exploit-DB entry 37292, associated with a Linux kernel OverlayFS local privilege-escalation vulnerability applicable to the old kernel family.

On Kali, SearchSploit can locate and copy the public exploit source:

```
searchsploit 37292
searchsploit -m 37292
```

The resulting source file was 37292.c. The file was not expected to exist on the target's web server. An earlier attempt to download it directly from http://192.168.29.32/37292.c returned HTTP 404 because that URL was not hosting the exploit.

12. Phase 10 — Transfer the Exploit to the Target

The exploit source was transferred from Kali to the target using SCP. The important point is that SCP was run from Kali because 37292.c existed on Kali, not initially on the target.

```
scp 37292.c itsskv@192.168.29.32:/home/itsskv/
```

The transfer completed successfully. On the target, the file was verified with:

```
ls -l ~/37292.c
```

The file appeared as /home/itsskv/37292.c with a size of 4968 bytes.

13. Phase 11 — Compile the Exploit

The C source code was compiled locally on the vulnerable target. Using the full path avoids confusion about the current working directory.

```
gcc /home/itsskv/37292.c -o /tmp/exploit
```

The compilation completed without errors. The resulting executable was verified with:

```
ls -l /tmp/exploit
```

14. Phase 12 — Privilege Escalation

The compiled exploit was executed inside the authorized CTF environment:

```
/tmp/exploit
```

The exploit displayed messages such as 'spawning threads', 'mount #1', 'mount #2', '/etc/ld.so.preload created', and 'creating shared library'. These messages indicate the exploit was performing the OverlayFS-related privilege-escalation sequence.

The exploit then returned a root shell. The shell prompt changed to '#', and the result was verified:

```
whoami
id
```

The observed 'whoami' output was 'root', confirming successful privilege escalation.

15. Phase 13 — Flag Discovery

After obtaining root, files could be searched across the filesystem. Useful commands included:

```
find / -type f -iname "*flag*" 2>/dev/null
find / -type f -iname "*final*" 2>/dev/null
find / -type f -name "final flag.txt" 2>/dev/null
ls -la /root
ls -la /
```

A file named flag2.txt was visible in the itsskv home directory during the root shell session. It could be read with:

```
cat ~/flag2.txt
```
For a filename containing spaces, quotation marks are required, for example:

```
cat "/root/final flag.txt"
```
Note that Linux filenames are case-sensitive. 'Desktop' and 'desktop' are different names.

16. Flags Collected

Stage	Flag / Artifact	Status
Flag 1	cybersploit{youtube.com/c/cybersploit}	Collected
Intermediate flag file	flag2.txt	File identified; value not recorded in this walkthrough
Final Flag	cybersploit{Z3X21CW42C4 many many congratulations !}	Collected

17. Complete Command Reference

The following is a compact command sequence representing the major steps performed in the lab:

```
# Kali — discover target
netdiscover
netdiscover -r 192.168.29.0/24

# Kali — enumerate services
nmap -sC -sV 192.168.29.32
nmap -p- -sC -sV 192.168.29.32

# Kali — SSH after obtaining credentials
ssh itsskv@192.168.29.32

# Target — local enumeration
uname -a
whoami
id

# Kali — find/copy Exploit-DB source
searchsploit 37292
searchsploit -m 37292

# Kali — transfer exploit
scp 37292.c itsskv@192.168.29.32:/home/itsskv/

# Target — verify, compile and execute
ls -l ~/37292.c
gcc /home/itsskv/37292.c -o /tmp/exploit
ls -l /tmp/exploit
/tmp/exploit

# Target — verify root
whoami
id

# Target — locate flags
find / -type f -iname "*flag*" 2>/dev/null
find / -type f -iname "*final*" 2>/dev/null
```

18. Attack-Chain Diagram

Kali → Network Discovery → 192.168.29.32 → Nmap → HTTP → Source-Code Analysis → Username 'itsskv' → robots.txt → Base64 → Password → SSH → uname -a → Old Kernel → Exploit-DB 37292 → 37292.c → SCP → GCC → /tmp/exploit → OverlayFS Privilege Escalation → root → Flags

19. Key Lessons Learned

- Perform network discovery before attempting exploitation.
- Always enumerate ports and service versions; the service list determines the likely attack surface.
- Inspect web source code and robots.txt during CTF reconnaissance.
- Base64 is encoding, not encryption; encoded credentials can often be recovered immediately.
- After obtaining a shell, perform local enumeration rather than stopping at initial access.
- uname -a is a fundamental command for identifying the kernel and architecture.
- Match kernel versions against public vulnerability research before attempting local privilege escalation.
- SCP must be run from the machine where the source file actually exists.
- A successful compile does not prove exploitation worked; verify with whoami and id.
- Linux paths and filenames are case-sensitive, and filenames containing spaces must be quoted.

20. Conclusion

The Cybersploit 1 machine was successfully compromised through a realistic multi-stage CTF workflow. The attack began with network and service enumeration, moved through web-based information disclosure and encoded credential discovery, established SSH access as itsskv, and culminated in local privilege escalation through a vulnerable Linux kernel. The final validation confirmed root access and enabled retrieval of the challenge flags.

CYBERSPLOIT 1 — WALKTHROUGH COMPLETE